

Module - 05

Vulnerability Assessment

→ **Vulnerability Assessment:** is the process of identifying, analyzing, and reporting security weaknesses in a system.

→ **Phases of Vulnerability Assessment:**

- Asset Discovery
- Vulnerability Identification
- Vulnerability Analysis
- Risk Assessment
- Prioritization
- Remediation
- Verification (Rescan)

→ **CVE: Common Vulnerabilities and Exposures**

CVE is a publicly available catalogue of known cybersecurity vulnerabilities maintained by MITRE.

The screenshot shows the Exploit Database interface for the entry "vsftpd 2.3.4 - Backdoor Command Execution". The interface includes a sidebar with navigation icons and a main content area with the following details:

EDB-ID:	CVE:	Author:	Type:	Platform:	Date:
49757	2011-2523	HERCULESRD	REMOTE	UNIX	2021-04-12

Below the table, there are three sections:

- EDB Verified:** ✓
- Exploit:** Download icon / Copy icon
- Vulnerable App:**

At the bottom, there is a code block containing the exploit details:

```
# Exploit Title: vsftpd 2.3.4 - Backdoor Command Execution
# Date: 9-04-2021
# Exploit Author: HerculesRD
# Software Link: http://www.linuxfromscratch.org/~thomasp/bifs-book-xsl/server/vsftpd.html
# Version: vsftpd 2.3.4
# Tested on: debian
# CVE : CVE-2011-2523

#!/usr/bin/python3

from telnetlib import Telnet
import sys
```

→Nessus: Nessus Professional is an assessment solution for identifying the vulnerabilities, configuration issues and malware.

[Back to My Scans](#)

ConfigureAudit TrailLaunchReportExport

Hosts1Vulnerabilities4Notes1History1

FilterSearch Vulnerabilities4 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count	
INFO				HTTP (Multiple Issues)	Web Servers	2	
INFO				Nessus SYN scanner	Port scanners	4	
INFO				Nessus Scan Information	Settings	1	
INFO				Web Server No 404 Error Code C...	Web Servers	1	

Scan Details

Policy: Web Application Tests
Status: Completed
Severity Base: CVSS v3.0
Scanner: Local Scanner
Start: Today at 11:43 AM
End: Today at 12:01 PM
Elapsed: 17 minutes

Vulnerabilities

- Critical
- High
- Medium
- Low
- Info

To see debug logs, please visit individual host

PortHosts

21 / tcp / ftp

Port 80/tcp was found to be open

To see debug logs, please visit individual host

PortHosts

80 / tcp / www

Port 443/tcp was found to be open

To see debug logs, please visit individual host

PortHosts

443 / tcp

Port 3306/tcp was found to be open

To see debug logs, please visit individual host

PortHosts

3306 / tcp / mysql

See Also

<http://www.nessus.org/u?d9c03a9a>

<http://www.nessus.org/u?b019cbdb>

[https://www.owasp.org/index.php/Test_HTTP_Methods_\(OTG-CONFIG-006\)](https://www.owasp.org/index.php/Test_HTTP_Methods_(OTG-CONFIG-006))

Output

Based on tests of each method :

- HTTP methods BASELINE-CONTROL CHECKIN CHECKOUT COPY DELETE GET
HEAD LABEL LOCK MERGE MKACTION MKCOL MKWORKSPACE MOVE OPTIONS
PATCH are allowed on :

/

To see debug logs, please visit individual host

Port ^

Hosts

80 / tcp / www

Priority	Service/Port	Critical Detail	Why this escalates the Attack
Critical	MySQL (3306)	Exposed Externally	Direct DB access. If credentials are weak/default, an attacker can bypass the web app entirely, dump data, or gain OS command execution.
Critical	FTP (21)	Service Exposed	File Upload/Data Theft. If anonymous login is enabled or credentials are weak, an attacker can upload web shells or steal configuration files containing passwords.
High	HTTPS (80/443)	WebDAV Enabled (PUT, DELETE, COPY, MOVE)	Remote File Manipulation. If these methods are not strictly authenticated, an attacker can overwrite the website (Defacement), upload a malicious shell, or delete critical files.